Claude Outlook Add-in: Security Brief

Oct 23, 2026 · @Tom

Summary

Recommendation: approve the add-in now for internal mail, and hold client mail until two contract questions are answered.

The add-in sends one email to Anthropic's API when the user clicks a button, and shows the reply in a window for the user to review. It cannot send mail, act on its own, or reach any other server. The technical risk is small and bounded.

The open risk is contractual: whether our Anthropic agreement covers API use, and whether client contracts allow client email to go to an AI provider.

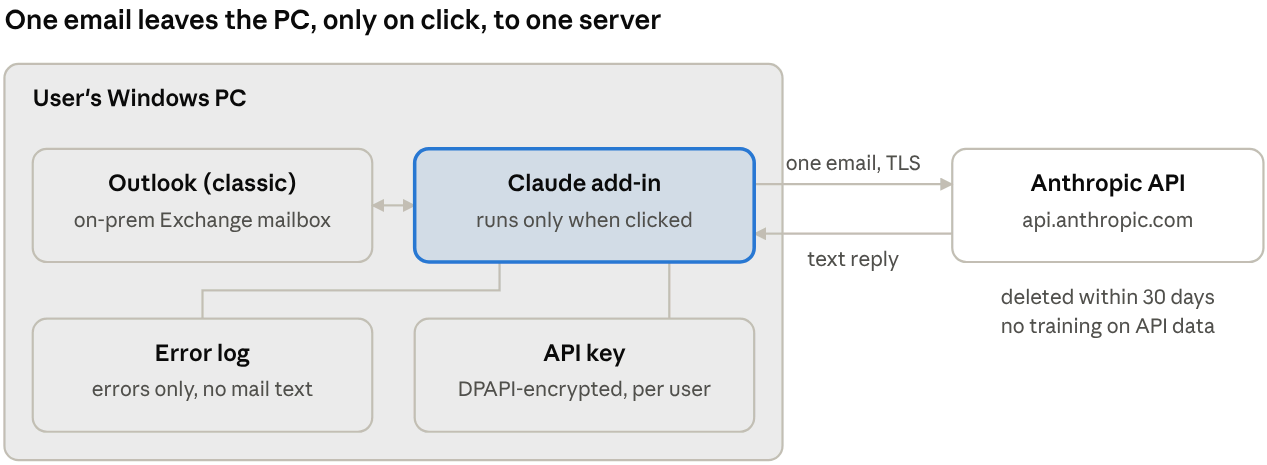
What the tool is

The tool is a COM add-in for classic Outlook on Windows (in use on Windows 10). It is built in-house for our mailboxes on on-premises Exchange. Anthropic's own Claude for Outlook add-in requires Exchange Online, so it is not an option for us.

- **Reading an email:** Summarize, Action items, Draft reply. A draft reply opens as a normal Outlook reply, unsent.
- **Writing an email:** Improve, Shorten, change the tone, turn notes into an email. These work on the selected text or on the user's own part of the draft.
- **Install:** per user, in the user's own registry hive. No admin rights, no Exchange changes, and nothing installed server-side.
- **Model:** Claude, called through Anthropic's API with the user's own Console API key. Replies are capped at 4,096 tokens.
- **Source:** about 1,700 lines of C# on .NET Framework 4.8, public on GitHub with no secrets in it (B1tR0n1n/outlook-claude, `com/` folder).

Data flow

Data leaves the PC only when the user clicks a Claude button, and it goes to one place: `https://api.anthropic.com/v1/messages`, over TLS 1.2 or later.



data flow · one PC, one destination

The key and the log stay on the PC. The only thing that crosses the boundary is the email the user clicked on, and the reply that comes back.

- **What is sent:** the open email's subject, sender, To, CC, received time and plain-text body, plus the user's instruction. Attachments are never sent.
- **What is also sent, if the user sets it:** a short "about me" note from settings, such as name and sign-off.
- **What comes back:** text, shown in a window. Nothing is written into a mailbox until the user clicks a button such as Replace Selection or Insert at Cursor, and nothing is ever sent.
- **Retention at Anthropic:** under standard API terms, inputs and outputs are deleted within 30 days (Anthropic retention policy). Zero data retention is available by agreement.
- **Training:** Anthropic's commercial terms do not allow training on API customer data. We still need to confirm that our agreement covers this key's org (see Decisions).

Controls in place

Each control below was checked in the source code on 2026-10-23.

Control	How it works
Single destination	The only URL in the code is `api.anthropic.com/v1/messages`. There is no telemetry, no update check and no other server.

Control	How it works
User-initiated only	No background work, timers or mailbox scanning. One click sends one email.
No sending or autonomy	The code never calls Outlook's Send. Claude has no tools; it returns text the user reads first. A malicious email (prompt injection) can at most produce a bad draft.
API key at rest	Encrypted with Windows DPAPI under the user's own Windows account, in the user's own registry hive. Other users and a stolen disk can't read it.
Logging	`%LOCALAPPDATA%\ClaudeOutlook\log.txt` records errors only, never email content or the key. It is capped at 256 KB.
Dependencies	At runtime it uses only Microsoft's Office interop libraries and .NET Framework, with no third-party packages.
Testing	79 automated tests cover the API request and errors, prompt building, draft handling and the Outlook ribbon. Key storage is Windows-only and is confirmed working on the installed copy, not covered by tests.

Residual risks

Risk	Severity	Mitigation
Client email reaches a third-party AI provider	High until the contracts are checked	Internal mail only until the decisions below are made.
Leftover plain-text key in the registry, for users who ran the earlier VBA macro version first	Medium	Delete `HKCU\Software\VB and VBA Program Settings\ClaudeOutlook` after saving settings once in the add-in. This disables the VBA macros, which the add-in replaces.

Risk	Severity	Mitigation
A leaked API key lets someone spend on our account	Medium	One key per user. A monthly spend limit on the key's Console workspace. Revoke in Console if a laptop is lost.
Malware running as the user can decrypt the key	Low (EDR in scope)	The same exposure as passwords saved in the browser. Revoke and rotate if the endpoint is compromised.
Unsigned DLL with no independent review	Low	The source is public and small enough to review in an hour. Code-sign it with our certificate before a wider rollout.
Wrong or invented content in a draft	Low	Every result is shown for review first, and nothing is ever sent automatically.

Decisions needed

Two questions settle whether client mail can be used. Both go to people outside IT.

1. **Does our Anthropic agreement cover API use?** The API key comes from a Console org that is not yet linked to our Claude Enterprise org. Ask the Anthropic account team to link the two, and to confirm in writing that the Enterprise DPA and no-training terms apply to API traffic.
2. **Do client contracts allow an AI provider to process client email?** Check the MSAs and DPAs for subprocessor approval, data residency and AI-use clauses. Any client with regulated data (HIPAA, CJIS, financial) needs its own answer. HIPAA mail requires a BAA with Anthropic first.

Proposed conditions of use until then:

- [ ] Internal mail only. No client email, and no email holding credentials, passwords or regulated data.
- [ ] One Console API key per user, with a monthly spend limit on the workspace.
- [ ] Remove any leftover plain-text key from the VBA version.
- [ ] Review every result before using it.

- [ ] Revisit once the two answers above are in. If both are yes, consider zero data retention and code signing before a team rollout.